

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (OWASP Dependency-Check + Maven) · Generated 2026-06-30 · Source: `pom.xml` · Branch: `fix/depSCAN-20260630-062017`

Summary

Metric	Count
Total CVEs found (baseline)	33
CVEs remediated this PR	26
CVEs remaining (MAJOR_REVIEW)	4
CRITICAL dependencies (post-fix)	0
HIGH dependencies (post-fix)	2
MEDIUM dependencies (post-fix)	2
Supply-chain alerts resolved	2

Fixes applied in this PR

Dependency	Old version	New version	CVEs cleared	CVSS max
org.apache.logging.log4j:log4j-core	2.14.1	2.17.1	CVE-2021-44228, CVE-2021-45046, CVE-2021-44832, CVE-2021-45105	10.0
org.apache.logging.log4j:log4j-api	2.14.1	2.17.1	CVE-2021-44228	10.0
com.fasterxml.jackson.core:jackson-databind	2.9.8	2.18.8	CVE-2019-14379, CVE-2019-14540, CVE-2020-36518, CVE-2022-42003, GHSA-j3rv-43j4-c7qm, +18 more	9.8
commons-io:commons-io	2.4	2.17.0	CVE-2024-47554, CVE-2021-29425	8.7
org.apache.commons:commons-lang3	3.4	3.18.0	CVE-2025-48924	6.5
com.fastxml.jackson.core:jackson-databind	2.9.8	REMOVED	Typosquatted coordinate (supply-chain)	—
HTTP repository <code>insecure-mirror.example.net</code>	present	REMOVED	MITM injection risk (supply-chain)	—

Remaining CVEs (require human review)

Dependency	Version	CVE	CVSS	Severity	Reason not auto-fixed
com.google.guava:guava	24.1.1-jre	CVE-2023-2976	5.5	MEDIUM	MAJOR_REVIEW: 24 → 32 major version jump
com.google.guava:guava	24.1.1-jre	CVE-2020-8908	7.5	HIGH	MAJOR_REVIEW: same
com.google.guava:guava	24.1.1-jre	CVE-2018-10237	5.9	MEDIUM	MAJOR_REVIEW: same

mysql:mysql-connector-java	8.0.30	CVE-2023-22102	8.9	HIGH	MAJOR_REVIEW: fix requires coordinate change to com.mysql:mysql-connector-j:9.2.0
----------------------------	--------	----------------	-----	------	---

Supply-chain alerts resolved

RESOLVED — Typosquatted dependency removed. `com.fastxml.jackson.core:jackson-databind:2.9.8` has been removed from `pom.xml`. Coordinate impersonated `com.fasterxml.jackson.core` ; absent from Maven Central.

RESOLVED — Untrusted HTTP repository removed. `http://insecure-mirror.example.net/maven2` has been removed. Plain-HTTP Maven repositories allow MITM artifact-injection attacks.

Machine-readable source: `depscan-report.json` . Generated by the *Dependency & Supply-Chain Plugin* — Stage 3 Auto-Remediation.